



INSTITUTO TECNOLÓGICO Y DE ESTUDIOS SUPERIORES DE MONTERREY

ESCUELA DE INGENIERÍA Y CIENCIAS
INGENIERÍA EN CIENCIA DE DATOS Y MATEMÁTICAS

GESTOR DE IDENTIDADES V1.0

Reporte Técnico

Socio Formador: Casa Monarca

Equipo de trabajo: 1 | **Grupo:** 603

Integrantes:

Miranda Cornejo Ahuja - A01571668
Natalia Cervantes González - A00838465
Hugo Jaime Valdés - A01384039
Jorge Alfonso Andujo Valdéz - A01563535
Ana Sofía Ibarra Ponce - A01285836

Profesores:

Raúl Gómez, Anas Wajid y Alberto F. Martínez

Monterrey, Nuevo León
30 de abril de 2023

Índice de Contenidos

- 1. Abstract 3
- 2. Introducción 3
- 3. Marco de Referencia 4
- 4. Desarrollo 5
 - 4.1. Propuesta 5
 - 4.2. Backend y Frontend 6
 - 4.3. Flujo Operativo 7
- 5. Resultados 8
 - 5.1. Backend 8
 - 5.2. Frontend 8
 - 5.3. Sistema Completo 9
 - 5.4. Casos de Uso 9
- 6. Conclusiones y Trabajo Futuro 10
- 7. Referencias 11
- 8. Anexos 11

1. Abstract

El presente reporte técnico describe el desarrollo de un sistema de gestión de identidades digitales para Casa Monarca, organización social que trabaja con población migrante y que requiere mecanismos seguros para la protección de información sensible. La solución propuesta utiliza criptografía de clave pública, certificados internos, autenticación de dos factores, control de acceso basado en roles y registros de auditoría para fortalecer la autenticidad, integridad, confidencialidad y trazabilidad de los procesos internos.

El sistema fue desarrollado con una arquitectura cliente-servidor, utilizando un frontend web y un backend basado en FastAPI. La plataforma permite administrar el ciclo de vida de los colaboradores, incluyendo alta, activación, desactivación, revocación y renovación de identidades digitales. Con ello, se busca proporcionar una base tecnológica segura, escalable y usable para apoyar los procesos administrativos y de seguridad de Casa Monarca.

2. Introducción

El reto correspondiente a esta unidad de formación tiene como objetivo diseñar y desarrollar soluciones tecnológicas basadas en criptografía de clave pública que permitan a la organización social Casa Monarca proteger información sensible, autenticar documentos y garantizar la seguridad en sus procesos digitales. Esto surge dentro del contexto de la ciberseguridad aplicada a organizaciones sin fines de lucro, particularmente aquellas que trabajan con poblaciones vulnerables, como migrantes, quienes requieren que sus datos personales y documentos sean manejados con altos estándares de protección y confidencialidad.

En este caso, la organización socio formadora Casa Monarca enfrenta la necesidad de fortalecer sus sistemas de manejo de información para cumplir con la Ley Federal de Protección de Datos Personales en Posesión de Particulares y con los Derechos ARCO: Acceso, Rectificación, Cancelación y Oposición. Este tipo de organizaciones manejan diariamente datos sensibles de las personas que apoyan, así como documentos oficiales y convenios con terceros como instituciones gubernamentales, proveedores y otras organizaciones. Sin mecanismos adecuados de seguridad digital, estos procesos pueden ser vulnerables a problemas como suplantación de identidad, falsificación de documentos, alteración de información o accesos no autorizados.

Como equipo, se busca desarrollar un conjunto de sistemas que integren mecanismos criptográficos de autenticidad, integridad, confidencialidad y no repudio en los procesos internos de la organización. Entre las soluciones contempladas se incluyen un sistema de gestión de identidades mediante certificados digitales, un sistema seguro de gestión y firma de documentos, herramientas para firmar y verificar correos electrónicos, mecanismos para validar externamente la autenticidad de documentos emitidos por la organización y un sistema para proteger y verificar la integridad de las bases de datos.

Además de la seguridad técnica, el proyecto pone un énfasis importante en la usabilidad y adaptabilidad. Las soluciones deben facilitar los procesos existentes en la organización, no complicarlos, de modo que puedan ser utilizadas por personal sin conocimientos avanzados en criptografía o ciberseguridad. También se busca que el sistema sea escalable y evolucione mediante un proceso

de desarrollo continuo basado en DevSecOps, permitiendo mejoras progresivas y la eventual integración con tecnologías como Blockchain en futuras etapas.

3. Marco de Referencia

Este proyecto se basa en conceptos de ciberseguridad y gestión de identidades digitales, enfocados en proteger información sensible dentro de organizaciones. En el caso de Casa Monarca, es importante asegurar los datos personales y documentos que manejan, ya que trabajan con poblaciones vulnerables y deben evitar riesgos como accesos no autorizados, suplantación de identidad o alteración de información.

Uno de los conceptos principales es la criptografía de clave pública. Este tipo de criptografía utiliza dos llaves: una privada, que solo conoce el usuario, y una pública, que se puede compartir. Esto permite autenticar usuarios, firmar documentos y asegurar la comunicación. Gracias a esto, se pueden crear identidades digitales confiables dentro de un sistema sin necesidad de compartir información sensible directamente.

Relacionado a esto, se utilizan certificados digitales, en particular del tipo X.509. Un certificado digital es un documento electrónico que vincula la identidad de una persona o entidad con una clave pública verificable. En particular, los certificados del estándar X.509 incluyen información como el nombre del sujeto, la entidad emisora, la clave pública, el periodo de validez y mecanismos de verificación. Estos certificados permiten validar la identidad de los usuarios dentro de un sistema, firmar documentos de manera segura y garantizar que la información venga de una fuente confiable.

Otro concepto clave es la gestión del ciclo de vida de las identidades digitales y certificados. Una identidad digital no es estática, sino que debe administrarse a lo largo del tiempo. Esto implica considerar diferentes estados como la creación, la revocación en caso de incidentes, la baja cuando el usuario deja de pertenecer a la organización y el rastreo de todas las acciones realizadas.

Dentro de este contexto, también es fundamental asegurar la integridad de la información, es decir, garantizar que los datos no han sido modificados sin autorización. Para ello se utilizan funciones hash, como SHA-256, que generan una huella única a partir de un conjunto de datos. Estas huellas permiten verificar que la información permanece intacta, ya que cualquier cambio, por mínimo que sea, produce un resultado completamente distinto.

Además de la autenticación y la integridad, el proyecto considera el control de acceso y la trazabilidad como elementos clave. El control de acceso permite definir qué acciones puede realizar cada usuario dentro del sistema, dependiendo de su rol y nivel de responsabilidad. Por su parte, la trazabilidad consiste en registrar todas las acciones realizadas, lo que permite dar seguimiento a los cambios y detectar posibles anomalías.

Asimismo, el proyecto se alinea con un enfoque de desarrollo moderno basado en DevSecOps, en el cual la seguridad se integra desde las primeras etapas del desarrollo y se mantiene a lo largo de todo el ciclo de vida del sistema. Este enfoque permite construir soluciones más robustas, adaptables y seguras.

Finalmente, la solución propuesta se integra con servicios de HostGator, un proveedor de hosting web que permite almacenar aplicaciones en servidores accesibles a través de internet. La arquitectura del sistema sigue el modelo cliente-servidor, con una separación clara entre frontend y backend.

En este contexto, la comunicación entre cliente y servidor debe protegerse mediante protocolos seguros como HTTPS.

4. Desarrollo

4.1. Propuesta

Se busca desarrollar un sistema de gestión de identidades enfocado en el manejo centralizado de identidades digitales de colaboradores mediante el uso de certificados internos. Esto permite administrar de forma segura el ciclo de vida de cada usuario dentro de la organización.

Se propone desarrollar un sistema de gestión de identidades digitales basado en criptografía de clave pública, en el cual cada colaborador de Casa Monarca pueda contar con una identidad digital institucional asociada a un certificado interno generado por el sistema. La identidad digital incorporará un identificador único, clave pública, estado de validez, fecha de emisión y expiración, así como una huella criptográfica de verificación de certificado.

El ciclo de vida de cada usuario será monitoreado y administrado mediante cuatro procesos:

1. Alta: generación de la identidad digital al registrar un nuevo colaborador.
2. Revocación: invalidación de la identidad en caso de incidente o pérdida de acceso.
3. Baja: desactivación definitiva cuando el usuario ya no tenga relación institucional.
4. Rastreo: consulta del historial de cambios de estado y operaciones realizadas.

El stack utilizado para el sistema es el siguiente:

- Frontend: React o Next.js exportado.
- Backend: FastAPI.
- Base de datos: MySQL 8.0.
- Criptografía: OpenSSL y librería `cryptography`.
- Hashes de integridad: `hashlib` con SHA-256.
- Correo: SMTP seguro.
- Seguridad de dominio y correo: DKIM, SPF y DMARC.
- Verificación externa: endpoint público para validar documentos.

Este sistema permitirá el rastreo de colaboradores, la administración de estados de validez, la consulta del historial de identidades y la generación de certificados internos. Con esta propuesta se podrá fortalecer el control institucional de identidades, mejorar la trazabilidad de accesos y establecer una base segura para futuras aplicaciones con firmas digitales, control de documentos y validación interna de procesos.

4.2. Backend y Frontend

Tabla 1. Componentes Backend y Frontend

Componente conceptual	Implementación real	Evidencia principal en el repositorio	Estado
Administrador	Usuario con <code>access_level.code = 1</code> y rol <code>SYSTEM_ADMIN</code> .	<code>models/user.py</code> , <code>models/access_level.py</code> , <code>services/permission_service.py</code>	Parcialmente implementado
Panel administrativo	Vistas React/Vite para administración de usuarios y auditoría.	<code>frontend/src/pages/UsersAdminPage.jsx</code> , <code>AuditPage.jsx</code> , <code>DashboardPage.jsx</code>	Implementado
API FastAPI	API versionada bajo <code>/api/v1</code> con dependencias de autenticación y autorización.	<code>app/main.py</code> , <code>app/core/deps.py</code> , <code>app/api/routes/</code>	Implementado
Gestor de identidades	<code>IdentityService</code> orquesta alta, activación, cambio de nivel, revocación y reemisión.	<code>services/identity_service.py</code> , <code>api/routes/identity.py</code>	Implementado
Autenticación	Flujo de dos pasos: contraseña + OTP, con JWT temporal y JWT final.	<code>services/auth_service.py</code> , <code>api/routes/auth.py</code> , <code>core/security.py</code>	Implementado
Roles y permisos	RBAC de cuatro niveles con roles y permisos granulares.	<code>models/role.py</code> , <code>models/permission.py</code> , <code>services/permission_service.py</code>	Implementado
Activación de cuenta	Token de activación con hash SHA-256 y transición de <code>PENDING</code> a <code>ACTIVE</code> .	<code>models/activation_token.py</code> , <code>repositories/activation_repository.py</code>	Implementado
Certificado interno	Certificado simplificado con RSA-2048, fingerprint y estado.	<code>models/certificate.py</code> , <code>services/crypto_service.py</code>	Implementado
Base de datos	ORM con <code>SQLAlchemy</code> y migraciones con <code>Alembic</code> .	<code>core/database.py</code> , <code>alembic/</code> , <code>models/</code>	Implementado
Auditoría	Bitácora por evento con actor, acción, resultado, hash y recurso.	<code>models/audit_log.py</code> , <code>services/audit_service.py</code> , <code>api/routes/audit.py</code>	Implementado

Correo	<code>NotificationService</code> con modo SMTP y fallback demo.	<code>services/notification_service.py</code> , <code>core/config.py</code>	Parcialmente implementado
Desactivación	Cambio de estado a <code>INACTIVE</code> y revocación del certificado activo.	<code>services/identity_service.py</code> <code>deactivate_user()</code>	Implementado
Revocación	Cambio de estado a <code>REVOKED</code> y revocación de certificado.	<code>services/identity_service.py</code> <code>revoke_user()</code>	Implementado
Renovación	Actualización de vigencia, reactivación y reemisión de certificado.	<code>services/identity_service.py</code> <code>update_user_expiry()</code> <code>reactivate_user()</code>	Parcialmente implementado

[Tabla 1. Componentes Backend y Frontend.]

4.3. Flujo Operativo

El acceso al panel requiere autenticación con contraseña y un segundo factor basado en OTP. El backend emite primero un JWT temporal de preautenticación y, una vez validado el OTP, genera el JWT final con estado autenticado.

Las rutas del frontend para administración y auditoría se encuentran protegidas tanto por sesión válida como por verificación del nivel de acceso. Posteriormente, el administrador puede registrar un nuevo colaborador ingresando nombre, correo, área, nivel y vigencia. El servicio `IdentityService` valida la unicidad del correo, recupera el rol por defecto del nivel, crea el usuario con estado pendiente y persiste la identidad.

Durante la provisión, se genera automáticamente un certificado simplificado basado en RSA-2048, con serial, fingerprint, fechas de emisión y expiración, y vínculo con el usuario. Después, el sistema crea un token aleatorio, persiste únicamente su hash SHA-256 y prepara el enlace de activación con vigencia temporal.

El colaborador recibe el enlace de activación por correo o, en modo demo, el enlace se registra para recuperación posterior. Al activar la cuenta, la ruta `/identity/activate` valida el token, marca la cuenta como activa, registra el consumo del token y permite establecer la contraseña inicial. Cada evento relevante queda registrado en `AuditLog`.

5. Resultados

5.1. Backend

El desarrollo del backend permitió implementar de forma funcional los principales componentes del sistema de gestión de identidades. A través de una arquitectura basada en FastAPI, se logró construir una API estructurada que gestiona el ciclo de vida completo de los usuarios dentro de la organización.

Se implementó el proceso de alta de colaboradores, en donde el sistema valida la unicidad del correo electrónico, asigna un rol y nivel de acceso, y registra la identidad con estado inicial pendiente. Como parte de este proceso, se integra el módulo criptográfico para la generación automática de certificados internos basados en RSA-2048. Estos certificados incluyen atributos como número de serie, huella digital y vigencia.

De la misma forma, se desarrolló el mecanismo de activación de cuentas mediante tokens. Este token permite al usuario completar su registro de manera segura y controlada, evitando accesos indebidos. En cuanto a la autenticación, se implementó un esquema de doble factor que combina credenciales tradicionales con un código OTP.

El backend también incorpora un modelo de control de acceso basado en roles, conocido como RBAC, el cual permite definir permisos granulares y niveles jerárquicos para cada usuario. Esto garantiza que las operaciones dentro del sistema estén restringidas de acuerdo con el perfil del colaborador.

Adicionalmente, se implementaron las siguientes funcionalidades clave:

- Desactivación de usuarios.
- Revocación de identidades.
- Renovación de vigencia.
- Registro de auditoría.
- Validación de estados de usuario y certificado.

5.2. Frontend

En el frontend se desarrolló una interfaz web funcional orientada a facilitar la administración del sistema de identidades digitales. Esta interfaz permite la interacción directa entre el usuario y los servicios del backend.

El panel administrativo permite gestionar colaboradores dentro de la organización. A través de este panel, se pueden realizar acciones como registrar nuevos usuarios, consultar información de identidades digitales, visualizar información relevante para la operación y gestionar estados de cuentas, incluyendo activación, revocación y desactivación.

Se desarrollaron las siguientes vistas específicas:

- Panel de administración de usuarios para el control de identidades.
- Panel de auditoría donde se visualizan eventos registrados en el sistema.
- Dashboard general que facilita la navegación.

El frontend se comunica correctamente con el backend, enviando y recibiendo solicitudes de manera consistente. Esto permite que el sistema sea accesible e intuitivo para usuarios sin conocimientos técnicos avanzados.

5.3. Sistema Completo

La integración de los componentes de frontend, backend y base de datos permite obtener un sistema funcional capaz de gestionar de manera segura las identidades digitales.

El sistema implementa el flujo completo de operación. Comienza con la autenticación del administrador mediante doble factor. Después de ser autenticado, el administrador puede registrar un nuevo colaborador, lo que desencadena automáticamente la generación de su identidad digital, incluyendo la emisión de un certificado interno y un token de activación.

Posteriormente, el colaborador recibe un enlace de activación para definir su contraseña y activar la cuenta. Una vez activada, la identidad digital queda disponible para iniciar sesión en el sistema mediante autenticación segura.

Durante el flujo mencionado, se mantiene lo siguiente:

- Autenticidad.
- Integridad.
- Confidencialidad.
- Trazabilidad.

Se logró una solución que integra múltiples componentes y cumple con el objetivo planteado. El sistema constituye una base sólida para futuras extensiones, como la integración de firmas digitales más avanzadas.

5.4. Casos de Uso

El sistema desarrollado contempla diversos casos de uso que están enfocados en la administración segura del ciclo de vida de las identidades digitales dentro de Casa Monarca. Los procesos principales engloban el alta de colaboradores, el donde el administrador autorizado registra nuevos usuarios, asigna niveles de acceso, genera certificados internos y crea tokens de activación para habilitar el acceso inicial del sistema.

Otro caso importante en este sistema es la activación de cuentas, donde los colaboradores pueden validar su identidad mediante la generación de un enlace temporal y poder establecer sus credenciales de acceso de forma segura. El sistema incorpora un mecanismo de autenticación de doble factor, el cuál fortalece el proceso de inicio de sesión mediante el uso de contraseñas y códigos OTP temporales.

Asimismo, se implementaron procesos administrativos para la desactivación y revocación de identidades digitales. Estas funciones permiten restringir accesos operativos a ciertos usuarios, invalidar certificados internos y nos permite mantener una trazabilidad histórica de todas las acciones que se realizan en la plataforma.

Estos casos de uso de encuentran respaldados por auditorías, control de acceso basado en roles y validaciones de seguridad que garantizan la integridad, la autenticidad y la confidencialidad de la

información manejada por el sistema. Toda esta información detallada en cuánto flujos, actores, precondiciones y resultados esperados se incluye en la sección de anexos del documento.

6. Conclusiones y Trabajo Futuro

El sistema de gestión de identidades digitales nos permitió implementar una solución funcional que está orientada a fortalecer la seguridad dentro de Casa Monarca. A través del uso de criptografía de clave pública, autenticación de dos factores y certificados internos con trazabilidad, se logró construir una arquitectura capaz de proteger y capturar información sensible de manera segura.

Otro aspecto relevante del proyecto es la usabilidad, buscando una solución que pudiera ser utilizada por personal sin tener conocimientos técnicos avanzados acerca de ciberseguridad. Esto es importante en organizaciones sociales como Casa Monarca, ya que es vital la eficiencia operativa y la protección de los datos, coexistiendo de forma práctica. Como trabajo futuro, se contempla la integración de firmas digitales avanzadas utilizando certificados completos, autoridades certificadoras internas y un registro completo mediante forms, para cumplir con los derechos ARCO. De igual manera se busca fortalecer la infraestructura de seguridad incorporando cifrado de bases de datos, monitoreo automatizado de incidentes y administración más robusta de llaves criptográficas.

Finalmente se espera continuar evolucionando la plataforma mediante un enfoque DevSecOps, incorporando pruebas de seguridad automatizadas, despliegues continuos y mecanismos de escalabilidad que permitan adaptar la solución a las necesidades e información de la organización. El proyecto establece una base sólida para construir herramientas digitales seguras que se enfoquen en la protección de poblaciones vulnerables y fortalecer la organización social.

7. Referencias

- ¿Qué es un certificado digital X.509? (2024). Centro de Ayuda de Webex. <https://help.webex.com/es-co/article/WBX42278/>
- Certificate Lifecycle | IT Security & Risk Documentation. (2023). Texas A&M University. <https://docs.security.tamu.edu/docs/identity-security/certificate-issuance/understanding-certificates/lifecycle/>
- Alanzi, H., & Alkhatib, M. (2022). Towards Improving Privacy and Security of Identity Management Systems Using Blockchain Technology: A Systematic Review. *Applied Sciences*, 12(23), 12415. <https://doi.org/10.3390/app122312415>
- National Institute of Standards and Technology. (2013). Digital Signature Standard (DSS), FIPS PUB 186-4. <https://doi.org/10.6028/NIST.FIPS.186-4>
- Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*. Pearson.
- Menezes, A., van Oorschot, P., & Vanstone, S. (1996). *Handbook of Applied Cryptography*. CRC Press.
- HostGator. (s.f.). Web Hosting Services. <https://www.hostgator.com/>
- Mozilla Developer Network. (s.f.). Client-server overview. https://developer.mozilla.org/en-US/docs/Learn/Server-side/First_steps/Client-Server_overview

8. Anexos

Repositorio de GitHub: https://github.com/mirandacornejoa/Reto_CasaMonarca_Eq1_603